

Postal address:
Box 8114
104 20 Stockholm
Website:
www.imy.se
Email:
imy@imy.se
Phone:
08-657 61 00
1(10)

Länsförsäkringar AB

106 50 Stockholm

Decision after supervision according to the
Data Protection Regulation -

Länsförsäkringar AB

Decision of the Swedish Authority for Privacy Protection

The Swedish Authority for Privacy Protection (Integritetsskyddsmyndigheten) finds that Länsförsäkringar AB (organization number 502010-9681) has processed personal data in violation of Article 32.1 of the Data Protection Regulation by failing to take appropriate technical and organizational measures to ensure an adequate level of security for personal data when using the analytics tool Meta-pixel during the period from March 10, 2021, to June 4, 2021.

The Swedish Authority for Privacy Protection issues a reprimand to Länsförsäkringar AB under Article 58.2 b of the Data Protection Regulation for the identified violation.

Report on the supervisory matter

Starting point for the supervision

The Swedish Authority for Privacy Protection (IMY) received a report of a personal data incident from Länsförsäkringar AB and an additional 26 companies within the Länsförsäkringsgruppen on June 7, 2021. The report indicated that the companies, when using Facebook's (now Meta's) service Facebook-pixel (now Meta-pixel), unlawfully transferred personal data to Meta for matching against Facebook profiles of an unknown number of individuals who visited the website www.lansforsakringar.se and provided information in forms. The transfer was caused by the Advanced Matching function being activated by mistake. The transfer to Meta occurred during the period from March 10, 2021, to June 4, 2021. Among the data transferred were identifying information and contact information. Länsförsäkringar AB became aware of the incident from an external source. As soon as Länsförsäkringar AB became aware of the incident, it deactivated the function.

On June 8, 2021, the report of the personal data incident was supplemented to include an additional company in the Länsförsäkringsgruppen. Given that the report indicated that all companies involved were data controllers for the incident that occurred on the website www.lansforsakringar.se, IMY initiated supervision against Länsförsäkringar AB and the other companies within the Länsförsäkringsgruppen that were involved in the personal data incident to investigate the information contained in the companies' report of the personal data incident. This matter has therefore been handled together with the supervisory matters against the other companies. The supervision has been limited to assessing the extent to which the companies have taken appropriate technical and organizational measures to protect the personal data of website visitors in accordance with Article 32.1 of the Data Protection Regulation during the period from March 10, 2021, to June 4, 2021, in connection with the transfer of personal data that occurred to Meta through the Advanced Matching function of the Meta-pixel.

The processing at IMY has taken place through written correspondence.

What Länsförsäkringar AB has stated

Länsförsäkringar AB and the other companies within the Länsförsäkringsgruppen that are subject to IMY's supervision have jointly expressed their views to IMY. The statement and the companies' report of the personal data incident primarily indicate the following regarding the issues that are the subject of

IMY's review.

Data controller

Länsförsäkringar AB and the other companies that are subject to IMY's supervision are data controllers for the implementation of the Meta-pixel, the Advanced Matching function, and the subsequent transfer of personal data to Meta.

The original implementation of the Meta-pixel

Länsförsäkringar AB has internal governing documents and formalized procedures for the processing of personal data. For example, there is a handbook easily accessible to staff regarding the processing of personal data, which includes information on what should be observed regarding ongoing or planned new personal data processing activities. The handbook also contains checklists to ensure that sufficient documentation is available for the assessments, decisions, and actions required before new personal data processing activities are initiated or ongoing personal data processing activities are changed. The purpose is to ensure compliance with the provisions of the Data Protection Regulation and other applicable data protection legislation. Such documents and procedures are applicable, among other things, when introducing new features on the website.

All staff undergo basic training in data protection, and targeted training efforts are made for certain categories of staff depending on whether and to what extent their work involves participation in ongoing or planned personal data processing activities.

The Meta-pixel has been implemented on the website so that Länsförsäkringar AB can conduct effective digital marketing by targeting relevant commercial messages to users based on which financial services the users have shown interest in on the website.

Swedish Authority for Privacy Protection

Diary Number: DI-2021-5568

3(10)

Date: 2024-12-19

Activation of the Subfunction Advanced Matching in the Meta Pixel

Länsförsäkringar AB has not duly decided to implement the service Advanced Matching.

Länsförsäkringar AB did not intend to activate the service. It has not been Länsförsäkringar AB's intention to process any personal data other than IP addresses in connection with the use of the Meta Pixel. Upon closer examination of the reason why the service Advanced Matching was activated, it has been established that staff had taken certain actions without realizing that these actions led to the service being used by all companies utilizing the website lansforsakringar.se.

Länsförsäkringar AB's Transfer of Personal Data via the Advanced Matching Function to Meta

During the period that Advanced Matching was in use, personal data was transferred to Meta in a so-called hashed encrypted form if users filled in information in forms on the website.

The personal data has been matched with Facebook profiles to target advertisements on Facebook based on the pages that the user visited on the website.

It has not been determined exactly how Advanced Matching has affected advertising. It cannot be ruled out that this resulted in targeted communication from Länsförsäkringar AB on Facebook. The function contributed to the following data being transferred:

- First and last name,
- Phone number,
- Email address, and
- Place of residence.

However, in not all cases were all data for each registered individual transferred to Meta; individual pieces of information may have been transferred, for example, just an email address.

The data was provided from forms on Länsförsäkringar AB's website, and no distinction was made regarding whether it was a customer or not who filled in the forms. The forms that could be filled out by users and that resulted in the filled-in data being transferred to Meta included, for example, forms for signing up for newsletters or expressing interest in learning more about a product or service. No information indicating that a user was or became a customer was included in the information in the forms shared with Meta.

According to information from Meta, the personal data was deleted within 48 hours of receipt. Due to the fact that the personal data was transferred to Meta in hashed encrypted form and has been deleted, it has not been possible to identify which or how many registered individuals have been affected by the incident.

Actions Taken After the Personal Data Incident

In response to the incident, Länsförsäkringar AB has reviewed its routines and the website's code structure to prevent similar situations from occurring. A dialogue

2 IMY's Addition: Hashing is a cryptographic one-way function that can be used to achieve pseudonymization, which is a possible security measure under Article 32 of the General Data Protection Regulation, by replacing personal data with a so-called hash value. This means that the replaced personal data is not available in plaintext and that additional information is needed to identify the registered individual.

Data Protection Authority

Diary Number: DI-2021-5568

4(10)

Date: 2024-12-19

with Meta and distributors of Meta's services has also been initiated to minimize the risk of personnel inadvertently activating Meta's services and features as occurred in this case.

Länsförsäkringar AB has implemented the following technical and organizational security measures to prevent and detect unauthorized outgoing traffic corresponding to that which was detected on June 4, 2021.

Several organizational security measures have been taken, such as a review of all permissions and access levels for employees with access to web-based tools. Stricter access requirements have been introduced; for example, all code changes related to tracking on the website require approval from two authorized employees. Affected employees have also received additional training to increase their knowledge of legislation regarding measurement and tracking in digital channels.

To further reduce the risk of unauthorized outgoing traffic, manual checks of settings and data flows in the tools used as part of the marketing process are also conducted regularly. An internal investigation is ongoing to review the conditions for automatically conducting checks of data flows from websites to third parties.

The current Meta pixel is turned off, and there are no plans to activate it again. Länsförsäkringar AB has implemented technical security measures that make the Advanced Matching service impossible, even if the Meta pixel were to be reintroduced in the future. Länsförsäkringar AB has also developed a filter to prevent the transmission of personal data from free text fields.

Justification of the Decision

Applicable Provisions, etc.

According to Article 95 of the General Data Protection Regulation, the General Data Protection Regulation shall not impose any additional obligations on natural or legal persons processing personal data for areas already covered by obligations under the so-called ePrivacy Directive. The ePrivacy Directive has been implemented in Swedish law through the Act (2022:482) on Electronic Communication (LEK), which regulates, among other things, the collection of data through cookies. According to Chapter 9, Section 28 of LEK, which implements Article 5.3 of the ePrivacy Directive, data may only be stored in or retrieved from a subscriber's or user's terminal equipment if the subscriber or user has access to information about the purpose of the processing and consents to it. Furthermore, it is stated that this does not prevent such storage or access that is necessary to transmit an electronic message via an electronic communications network or that is necessary to provide a service that the user or subscriber has expressly requested. LEK came into force on June 3, 2022. However, during the relevant time in this case, the same requirements applied according to Chapter 6, Section 18 of the Act (2003:389) on Electronic Communication. The Swedish Post and Telecom Authority is the supervisory authority according to LEK (Chapter 1, Section 5 of the Regulation (2022:511) on Electronic Communication).

3 Directive 2002/58/EC of the European Parliament and of the Council of July 12, 2002, on the processing of personal data and the protection of privacy in the electronic communications sector (Directive on Privacy and Electronic Communications).

Integrity Protection Authority

Diary Number: DI-2021-5568

5(10)

Date: 2024-12-19

The European Data Protection Board (EDPB) has commented on the interaction between the ePrivacy Directive and the General Data Protection Regulation (GDPR). The opinion states, among other things, that the national supervisory authority designated under the ePrivacy Directive is solely competent to monitor compliance with the directive. In contrast, the supervisory authority under the GDPR is the competent supervisory authority for processing that is not specifically regulated by the ePrivacy Directive.

On October 7, 2024, the EDPB adopted guidelines regarding the technical scope of Article 5.3 of the ePrivacy Directive. The guidelines indicate, among other things, that a common approach for companies is the use of unique identifiers or persistent identifiers. Such identifiers can be derived from persistent personal data (first name, last name, email address, phone number, etc.) which are hashed on the user's device, collected, and shared among several data controllers to uniquely identify a person through various datasets (user data collected through the use of a website or application, customer relationship management related to online or offline purchases or subscriptions, etc.). The guidelines clarify that the fact that the information is entered by the user does not exclude the applicability of Article 5.3 of the ePrivacy Directive since the information is temporarily stored on the terminal before it is collected. Regarding collection through unique identifiers on websites or mobile applications, the collecting party provides instructions to the browser (through code that is distributed to the terminal/client) which sends the information. Thus, data retrieval occurs, and Article 5.3 is applicable. The fact that the collecting party instructing the terminal to send back the information is not the same as the one receiving the information does not exclude the applicability of Article 5.3 of the ePrivacy Directive.

According to Article 4.7 of the GDPR, the data controller is a natural or legal person, public authority, agency, or other body that alone or jointly with others determines the purposes and means of the processing of personal data. If the purposes and means of processing are determined by Union law or the national law of the Member States, the data controller or the specific criteria for how it is to be designated may be provided for in Union law or in the national law of the Member States.

The data controller shall, according to Article 5.2 of the GDPR, be responsible for and be able to demonstrate compliance with the fundamental principles set out in Article 5.1 of the GDPR (the principle of accountability).

Article 32.1 of the GDPR states that the data controller shall implement appropriate technical and organizational measures to ensure a level of security appropriate to the risk of processing. In assessing which technical and organizational measures are appropriate, the data controller shall take into account the state of the art, the costs of implementation, and the nature, scope, context, and purposes of processing as well as the risks to the rights and freedoms of natural persons.

According to Article 32.1, appropriate protective measures, where appropriate, include

- Pseudonymization and encryption of personal data.

4 Opinion 5/2019 on the interaction between the Directive on Privacy and Electronic Communications and the General Data Protection Regulation, particularly regarding the competence, tasks, and powers of data protection authorities, adopted on March 12, 2019, paragraphs 68 and 69.

5 EDPB Guidelines 2/2023 on Technical Scope of Art. 5(3) of ePrivacy Directive, paragraphs 61–63.

6 Ibid, paragraph 34.

Swedish Authority for Privacy Protection

Diary Number: DI-2021-5568

6(10)

Date: 2024-12-19

•

The ability to continuously ensure confidentiality, integrity, availability, and resilience of the processing systems and services.

•

The ability to restore availability and access to personal data in a reasonable time in the event of a physical or technical incident.

•

A procedure for regularly testing, examining, and evaluating the effectiveness of the technical and organizational measures intended to ensure the security of processing.

According to Article 32.2 of the General Data Protection Regulation, when assessing the appropriate level of security, special consideration shall be given to the risks posed by the processing, in particular for accidental or unlawful destruction, loss, or alteration, or for unauthorized disclosure of or unauthorized access to personal data that has been transmitted, stored, or otherwise processed.

Recital 75 of the General Data Protection Regulation specifies factors to be considered when assessing the risk to the rights and freedoms of natural persons. Among other things, the loss of confidentiality concerning personal data that is subject to confidentiality obligations is mentioned, as well as whether the processing concerns data about health or sexual life. Furthermore, consideration should be given to whether the processing involves personal data concerning vulnerable natural persons, especially children, or whether the processing involves a large amount of personal data and concerns a large number of data subjects.

Recital 76 of the General Data Protection Regulation states that how likely and severe the risk to the rights and freedoms of the data subject is should be determined based on the nature, scope, context, and purposes of the processing. The risk should be assessed based on an objective evaluation, through which it is determined whether the data processing involves a risk or a high risk.

Assessment by the Swedish Authority for Privacy Protection

IMY shall initially determine whether the General Data Protection Regulation is applicable and whether IMY is the competent supervisory authority. If so, IMY shall examine whether Länsförsäkringar AB is the data controller and whether the company has taken appropriate security measures in accordance with Article 32 of the General Data Protection Regulation to protect the personal data processed during the use of the Meta pixel with the Advanced Matching feature activated during the period from March 10 to June 21, 2021.

IMY is the competent supervisory authority

IMY's review focuses on Länsförsäkringar AB's use of the Meta pixel, a script-based tool in the form of a code snippet, on Länsförsäkringar AB's website, where the Advanced Matching feature was later activated. The Advanced Matching feature has resulted in the Meta pixel instructing users' browsers to collect and hash information in the form of the personal data that users have provided on the page.

Based on this information, a unique identifier has been created that is temporarily stored in the user's terminal and then transferred to, and thus retrieved by, Meta for matching. The processing in question has thus included both such storage in and retrieval from users' terminal equipment as referred to in Chapter 9, Section 28 of the Electronic Communications Act (LEK), and the corresponding provision in Chapter 6, Section 18 of the Act (2003:389) on electronic communications.

The Swedish Post and Telecom Authority is solely competent to supervise the application of LEK.

However, IMY's review concerns whether Länsförsäkringar AB has taken sufficient measures.

Swedish Authority for Privacy Protection

Diary Number: DI-2021-5568

7(10)

Date: 2024-12-19

security measures, which is not specifically regulated in the LEK. IMY is therefore

authorized to investigate the matter that the supervisory case concerns.

Länsförsäkringar AB is the data controller

Länsförsäkringar AB has stated that it is the data controller for the personal data processing that has been reviewed in the case. The investigation shows that the purpose of implementing and using the Meta pixel was to optimize Länsförsäkringar AB's marketing. By processing data about visitors' behavior on the website, Länsförsäkringar AB's marketing on Meta's service Facebook has thus been optimized.

IMY notes that Länsförsäkringar AB has determined how the processing should take place and for what purpose the personal data should be processed. IMY therefore assesses that it is Länsförsäkringar AB that, according to Article 4.7 of the General Data Protection Regulation, is the data controller for the personal data processing that the supervision encompasses.

Has Länsförsäkringar AB ensured an appropriate level of security for the personal data?

The processing has involved a risk

The data controller must take measures to ensure a level of protection that is appropriate based on the risks associated with the processing. The assessment of an appropriate level of protection should take into account, among other things, the nature, scope, context, and purposes of the processing, as well as the risks, varying in probability and severity, to the rights and freedoms of natural persons. Based on an objective assessment, it should be determined whether the processing entails a risk or a high risk.

The investigation in the case shows that Länsförsäkringar AB, by introducing the Meta pixel and the Advanced Matching function, inadvertently transferred data to Meta regarding names and contact details of website visitors who had provided such information in forms on Länsförsäkringar AB's website.

IMY makes the following assessment of the risks associated with the processing of the registered individuals' personal data.

The registered individuals have provided, among other things, names and contact details to a company engaged in insurance activities, and the data has thus occurred in a context where the registered individuals must have been able to expect a high degree of confidentiality. Länsförsäkringar AB had procedures in place that were followed during the introduction of the Meta pixel. The Meta pixel was thus implemented in such a way that when the Advanced Matching function was activated, only a limited number of data about a registered individual was transferred, which did not reveal whether the registered individual was a customer of Länsförsäkringar AB or related to data in a registered individual's potential customer relationship with Länsförsäkringar AB. The number of registered individuals affected by the incident could not be identified.

In summary, IMY assesses that the processing, considering its nature, scope, and context, has involved a risk that has resulted in a requirement for Länsförsäkringar AB to ensure a level of protection that is appropriate in relation to the current risk. The measures should, among other things, ensure that the personal data is protected against loss of control.

Swedish Authority for Privacy Protection

Case Number: DI-2021-5568

8(10)

Date: 2024-12-19

Länsförsäkringar AB has not taken adequate protective measures

IMY will subsequently assess whether Länsförsäkringar AB has ensured the level of protection required to safeguard the personal data of the registered individuals.

According to the information provided by Länsförsäkringar AB, they have formalized procedures to ensure the correct processing of personal data before, during, and after the implementation of new features on the website, and that these procedures are documented in Länsförsäkringar AB's governing documents.

IMY notes that Länsförsäkringar AB has thus had organizational measures in place in the form of procedures that are documented in Länsförsäkringar AB's governing documents.

However, in this particular case, Länsförsäkringar AB did not follow its procedures. Länsförsäkringar

AB had the Meta pixel implemented on its website, and the Advanced Matching function in the Meta pixel was subsequently activated without Länsförsäkringar AB being aware of it. As a consequence of Länsförsäkringar AB not following its procedures during the implementation of this function and not documenting what occurred, it has not been possible for Länsförsäkringar AB to detect and subsequently verify how or by whom this function was activated.

As a result of the Advanced Matching function being activated without Länsförsäkringar AB's knowledge, Länsförsäkringar AB transferred data to Meta about website visitors that were not intended to be transferred.

Länsförsäkringar AB has thus lacked the ability to detect the ongoing transfer of personal data to Meta. IMY believes that Länsförsäkringar AB should have had such systematic security work that this would have been detected by Länsförsäkringar AB. Such security work includes conducting checks with certain regularity. Since Länsförsäkringar AB has only had procedures for following up documented changes made according to established procedures, Länsförsäkringar AB has lacked the ability to detect and address changes that, as in this case, were made without following the procedures. Against this background, IMY concludes that Länsförsäkringar AB has lacked technical and organizational security procedures to systematically follow up and detect unintentional changes in its systems. As a result of Länsförsäkringar AB both not applying its organizational security procedures when it implemented the Advanced Matching function, and lacking organizational and technical security procedures to detect transfers, personal data about an unknown number of individuals has been unlawfully transferred to Meta.

In summary, IMY finds that Länsförsäkringar AB, in its use of the Meta pixel, has not taken adequate technical and organizational measures to ensure a level of security that was appropriate in relation to the risk. This means that Länsförsäkringar AB has processed personal data in violation of Article 32.1 of the General Data Protection Regulation during the period from March 10, 2021, to June 4, 2021.

Choice of Intervention

According to Article 58.2 and Article 83.2 of the General Data Protection Regulation, IMY has the authority to impose an administrative fine. Depending on the circumstances of the individual case, an administrative fine shall be imposed in addition to or instead of the other measures referred to in Article 58.2, such as orders and prohibitions. If it concerns a minor infringement, IMY may, according to what is stated in Recital 148, instead of imposing a fine, issue a reprimand in accordance with Article 58.2 b. Consideration shall be given to aggravating and mitigating circumstances in the case, such as the nature, severity, and duration of the infringement, as well as previous relevant infringements.

The established infringement has occurred because Länsförsäkringar AB processed personal data with an insufficient level of security, which led to Länsförsäkringar AB transferring more personal data than intended about an unknown number of registered individuals to Meta over a period of nearly three months. Länsförsäkringar AB has lacked the ability to independently detect the transfer of personal data to Meta during this time.

The infringement has occurred in insurance operations where the registered individuals must be considered to have had a legitimate expectation of a high degree of confidentiality. However, Länsförsäkringar AB has taken measures that limited the intrusion into the personal privacy of the registered individuals. Länsförsäkringar AB has placed the Meta pixel on its website in such a way that information indicating that a registered individual was a customer of Länsförsäkringar AB could not be inferred from the data transferred to Meta when the Advanced Matching function was activated. Thus, it has not involved data that was subject to confidentiality. The data transferred has involved relatively few personal data concerning each registered individual and has not concerned sensitive personal data. Furthermore, the transfer occurred over a shorter time interval. The personal data has been transferred in a hashed, that is, unreadable, format to a single recipient, and thus it does not involve uncontrolled disclosure where the data has, for example, been shared with many unauthorized parties or made publicly available. In an overall assessment, IMY finds that this constitutes a minor infringement as referred to in Recital 148 of the General Data Protection Regulation and that Länsförsäkringar AB should therefore be given a reprimand.

This decision has been made by the unit manager Catharina Fernquist after presentation by senior

lawyer Hans Kärnlöf. In the final handling of the case, IT and information security specialist Petter Flink has also participated.

Catharina Fernquist

Copy to

Länsförsäkringar AB's Data Protection Officer

Swedish Authority for Privacy Protection

Case Number: DI-2021-5568

10(10)

Date: 2024-12-19

How to Appeal

If you wish to appeal the decision, you must write to the Swedish Authority for Privacy Protection. In your letter, specify which decision you are appealing and the change you are requesting. The appeal must be received by the Swedish Authority for Privacy Protection no later than three weeks from the date you received notice of the decision. If the appeal is submitted in a timely manner, the Swedish Authority for Privacy Protection will forward it to the Administrative Court in Stockholm for review. You may email the appeal to the Swedish Authority for Privacy Protection if it does not contain any sensitive personal data or information that may be subject to confidentiality. The authority's contact details are provided on the first page of the decision.